

Situacion

Resumen de la actividad

En esta actividad, asumirás el papel de un analista de ciberseguridad que trabaja para una empresa que aloja el sitio web de cocina, yummyrecipesforme.com. Los visitantes del sitio web experimentan un problema de seguridad al cargar la página web principal. Tu trabajo consiste en investigar, identificar, documentar y recomendar una solución al problema de seguridad.

Cuando investigue el evento de seguridad, revisará un registro tcpdump. Tendrás que identificar los Protocolos de red utilizados para establecer la conexión entre el usuario y la página web. Los Protocolos de red son las reglas y estándares de comunicación que los dispositivos en red utilizan para transmitir datos. Desafortunadamente, los actores maliciosos también pueden utilizar protocolos de red para invadir y atacar redes privadas. Saber identificar los protocolos utilizados habitualmente en los ataques le ayudará a proteger la red de su organización contra este tipo de eventos de seguridad.

Para completar la tarea, también tendrá que documentar lo que ocurrió durante el incidente de seguridad. A continuación, recomendará una medida de seguridad para prevenir problemas de seguridad similares en el futuro.

Asegúrese de completar esta actividad antes de continuar. El siguiente punto del curso le proporcionará un ejemplo completado para que lo compare con su propio trabajo.

Escenario

Revise el escenario que aparece a continuación. Luego complete las instrucciones paso a paso.

Usted es un analista de ciberseguridad para yummyrecipesforme.com, un sitio web que vende recetas y libros de cocina. Un antiguo empleado ha decidido atraer a los usuarios a un sitio web falso con malware.

El antiguo empleado/hacker ejecutó un ataque de fuerza bruta para obtener acceso al host web. Introdujeron repetidamente varias contraseñas predeterminadas conocidas para la cuenta administrativa hasta que acertaron con la correcta. Una vez obtenidas las credenciales de inicio de sesión, pudieron acceder al panel de administración y cambiar el código fuente del sitio web. Incrustaron una función javascript en el código fuente que pedía a los visitantes que descargaran y ejecutaran un archivo al visitar el sitio web. Después de incrustar el programa malicioso, el hacker cambió la contraseña de la cuenta administrativa. Cuando los clientes descargaban el archivo, eran redirigidos a una versión falsa del sitio web que contenía el programa malicioso.

Varias horas después del ataque, varios clientes enviaron correos electrónicos al servicio de asistencia de yummyrecipesforme. Se quejaban de que el sitio web de la empresa les había incitado a descargar un archivo para acceder a recetas gratuitas. Los clientes afirmaron que, tras ejecutar el archivo, la dirección del sitio web cambió y sus ordenadores personales empezaron a funcionar más lentamente.

En respuesta a este incidente, el propietario del sitio web intenta acceder al panel de administración, pero no lo consigue, por lo que se pone en contacto con el proveedor de alojamiento del sitio web. Usted y otros analistas de Ciberseguridad reciben el encargo de investigar este incidente de seguridad.

Para abordar el incidente, creas un entorno sandbox para observar el comportamiento sospechoso del sitio web. Ejecutas el analizador de protocolos de red tcpdump y escribes la URL del sitio web, yummyrecipesforme.com. En cuanto se carga el sitio web, se le pide que descargue un archivo ejecutable para actualizar su navegador. Aceptas la descarga y dejas que se ejecute el archivo. Entonces observa que su navegador le redirige a una URL diferente, greatrecipesforme.com, que contiene el malware.

Los registros muestran el siguiente proceso

El navegador inicia una petición DNS: Solicita la dirección IP de la URL yummyrecipesforme.com al servidor DNS.

El DNS responde con la dirección IP correcta.

El navegador inicia una petición HTTP: Solicita la página web yummyrecipesforme.com utilizando la dirección IP enviada por el servidor DNS.

El navegador inicia la descarga del malware.

El navegador inicia una petición DNS para recetasriquitasforme.com.

El servidor DNS responde con la dirección IP de greatrecipesforme.com.

El navegador inicia una petición HTTP a la dirección IP de greatrecipesforme.com.

Un analista senior confirma que el sitio web ha sido comprometido. El analista comprueba el código fuente del sitio web. Observan que se ha añadido código javascript para pedir a los visitantes del sitio web que descarguen un archivo ejecutable. El análisis del archivo descargado encontró un script que redirige los navegadores de los visitantes de yummyrecipesforme.com a greatrecipesforme.com.

El equipo de ciberseguridad informa de que el servidor web fue afectado por un ataque de fuerza bruta. El hacker descontento pudo adivinar fácilmente la contraseña porque la

contraseña de administrador seguía siendo la contraseña por defecto. Además, no había controles para prevenir un ataque de fuerza bruta.

Tu trabajo es documentar el incidente en detalle, incluyendo la identificación de los protocolos de red utilizados para establecer la conexión entre el usuario y el sitio web. También debes recomendar una acción de seguridad a tomar para prevenir ataques de fuerza bruta en el futuro.

Activity Summary

Activity Summary

In this activity, you will assume the role of a cybersecurity analyst working for a company that hosts the cooking website, yummyrecipesforme.com. Website visitors are experiencing a security issue when loading the main webpage. Your job is to investigate, identify, document, and recommend a solution to the security problem.

When investigating the security event, you will review a tcpdump log. You will need to identify the network protocols used to establish the connection between the user and the webpage. Network protocols are the communication rules and standards that networked devices use to transmit data. Unfortunately, malicious actors can also use network protocols to invade and attack private networks. Knowing how to identify the protocols commonly used in attacks will help you protect your organization's network against these types of security events.

To complete the task, you will also need to document what happened during the security incident. Next, you will recommend a security measure to prevent similar security problems in the future.

Make sure to complete this activity before continuing. The next point in the course will provide you with a completed example for you to compare with your own work.

Scenario

Review the scenario below. Then complete the step-by-step instructions.

You are a cybersecurity analyst for yummyrecipesforme.com, a website that sells recipes and cookbooks. A former employee has decided to lure users to a fake website with malware. The former employee/hacker executed a brute-force attack to gain access to the web host. They repeatedly entered various known default passwords for the administrative account until they hit the correct one. Once the login credentials were obtained, they were able to access the admin panel and change the website's source code. They embedded a javascript function into the source code that prompted visitors to download and execute a file when visiting the website. After embedding the malicious program, the hacker changed the administrative account password. When customers downloaded the file, they were redirected to a fake version of the website that contained the malicious program.

Several hours after the attack, multiple customers sent emails to the [yummyrecipesforme](http://yummyrecipesforme.com) help desk. They complained that the company's website had prompted them to download a file to access free recipes. Customers stated that after running the file, the website address changed, and their personal computers started running much slower.

In response to this incident, the website owner tries to access the admin panel but is unsuccessful, so they contact the website hosting provider. You and other cybersecurity analysts are tasked with investigating this security incident.

To address the incident, you create a sandbox environment to observe the website's suspicious behavior. You run the network protocol analyzer tcpdump and type the website URL, yummyrecipesforme.com. As soon as the website loads, you are prompted to download an executable file to update your browser. You accept the download and let the file run. Then you

observe your browser redirecting you to a different URL, greatrecipesforme.com, which contains the malware.

The logs show the following process:

The browser initiates a DNS request: It requests the IP address of the URL yummyrecipesforme.com from the DNS server.

The DNS responds with the correct IP address.

The browser initiates an HTTP request: It requests the webpage yummyrecipesforme.com using the IP address sent by the DNS server.

The browser starts the malware download.

The browser initiates a DNS request for greatrecipesforme.com.

The DNS server responds with the IP address of greatrecipesforme.com.

The browser initiates an HTTP request to the IP address of greatrecipesforme.com.

A senior analyst confirms that the website has been compromised. The analyst checks the website's source code. They observe that javascript code has been added to ask website visitors to download an executable file. Analysis of the downloaded file found a script that redirects visitors' browsers from yummyrecipesforme.com to greatrecipesforme.com.

The cybersecurity team reports that the web server was affected by a brute-force attack. The disgruntled hacker was able to easily guess the password because the admin password was still the default password. Additionally, there were no controls to prevent a brute-force attack.

Your job is to document the incident in detail, including identifying the network protocols used to establish the connection between the user and the website. You must also recommend a security action to take to prevent brute-force attacks in the future.

Informe de incidente de seguridad

Informe de incidente de seguridad

Sección 1: Identificar el protocolo de red involucrado en el incidente

El protocolo principal involucrado en el incidente es HTTP (Hypertext Transfer Protocol). El análisis de los registros de tráfico de red mediante tcpdump confirmó que la interacción inicial con el servidor web se realizó a través de este protocolo en la capa de aplicación. Esta actividad quedó evidenciada en el siguiente fragmento del log, donde se observa claramente la petición hacia el dominio legítimo:

```
14:18:36.786589 IP your.machine.36086 > yummyrecipesforme.com.http: Flags [P.], seq 1:74, ack 1, win 512, options [nop,nop,TS val 3302576859 ecr 3302576859], length 73: HTTP: GET / HTTP/1.1
```

Adicionalmente, se observó la actividad del protocolo DNS, el cual resolvió en primera instancia la IP de *yummyrecipesforme.com* (203.0.113.22) y, tras la descarga del archivo malicioso por HTTP, registró un cambio abrupto al resolver la IP del sitio web suplantado *greatrecipesforme.com* (192.0.2.172).

Sección 2: Documentar el incidente

Varios clientes reportaron que sus computadoras operaban con extrema lentitud tras visitar nuestro sitio web. Para investigar sin comprometer la red, se utilizó un entorno aislado (sandbox) y se capturó el tráfico con tcpdump. La investigación forense determinó que un atacante (posiblemente un antiguo empleado) obtuvo acceso al panel de administración mediante un ataque de fuerza bruta para adivinar la contraseña. Una vez dentro, el atacante inyectó código malicioso en el sitio web original. Este código forzaba a los usuarios legítimos a descargar e instalar un malware encubierto. Tras la ejecución de este archivo en las computadoras de los clientes —lo cual causó la degradación del rendimiento de sus equipos—, el tráfico de red de los usuarios fue redirigido hacia un sitio web suplantado.

Sección 3: Recomiende una medida correctiva para los ataques de fuerza bruta.

Para mitigar futuros ataques de fuerza bruta, se implementarán las siguientes medidas de seguridad en conjunto:

- Políticas de Bloqueo: Configurar el panel de inicio de sesión para que bloquee automáticamente la cuenta del usuario tras un máximo de 3 intentos fallidos.
- Autenticación de Dos Factores (2FA): Implementar 2FA de forma obligatoria, requiriendo que los administradores validen su identidad ingresando su contraseña y un código de un solo uso (OTP) enviado a su dispositivo móvil o correo.
- Gestión de Contraseñas: Exigir una política de contraseñas de alta complejidad, forzar su rotación cada mes para dificultar su adivinación, y configurar el sistema para rechazar explícitamente el uso de contraseñas anteriores o por defecto.

Security Incident Report

Security Incident Report

Section 1: Identify the network protocol involved in the incident

The primary protocol involved in the incident is HTTP (Hypertext Transfer Protocol). Analysis of the network traffic logs using tcpdump confirmed that the initial interaction with the web server was carried out through this protocol at the application layer. This activity was evidenced in the following log snippet, which clearly shows the request to the legitimate domain:

```
14:18:36.786589 IP your.machine.36086 > yummyrecipesforme.com.http: Flags [P.], seq 1:74, ack 1, win 512, options [nop,nop,TS val 3302576859 ecr 3302576859], length 73: HTTP: GET / HTTP/1.1
```

Additionally, DNS protocol activity was observed, which initially resolved the IP of *yummyrecipesforme.com* (203.0.113.22) and, after the malicious file was downloaded via HTTP, registered an abrupt change when resolving the IP of the spoofed website *greatrecipesforme.com* (192.0.2.172).

Section 2: Document the incident

Several customers reported that their computers were running extremely slowly after visiting our website. To investigate without compromising the network, an isolated environment (sandbox) was used, and traffic was captured with tcpdump. Forensic investigation determined that an attacker (possibly a former employee) gained access to the administration panel through a brute force attack to guess the password. Once inside, the attacker injected malicious code into the original website. This code forced legitimate users to download and install covert malware. After the execution of this file on customers' computers—which caused the performance degradation of their equipment—, user network traffic was redirected to a spoofed website.

Section 3: Recommend a corrective measure for brute force attacks.

To mitigate future brute force attacks, the following security measures will be implemented collectively:

- **Blocking Policies:** Configure the login panel to automatically block the user's account after a maximum of 3 failed attempts.
- **Two-Factor Authentication (2FA):** Mandatorily implement 2FA, requiring administrators to validate their identity by entering their password and a one-time code (OTP) sent to their mobile device or email.
- **Password Management:** Require a high-complexity password policy, enforce its rotation every month to make guessing difficult, and configure the system to explicitly reject the use of previous or default passwords.

TCPdump

14:18:32.192571 IP your.machine.52444 > dns.google.domain: 35084+ A?
yummyrecipesforme.com. (24)
14:18:32.204388 IP dns.google.domain > your.machine.52444: 35084 1/0/0 A
203.0.113.22 (40)

14:18:36.786501 IP your.machine.36086 > yummyrecipesforme.com.http: Flags
[S], seq 2873951608, win 65495, options [mss 65495,sackOK,TS val 3302576859
ecr 0,nop,wscale 7], length 0
14:18:36.786517 IP yummyrecipesforme.com.http > your.machine.36086: Flags
[S.], seq 3984334959, ack 2873951609, win 65483, options [mss 65495,sackOK,TS
val 3302576859 ecr 3302576859,nop,wscale 7], length 0
14:18:36.786529 IP your.machine.36086 > yummyrecipesforme.com.http: Flags
[.], ack 1, win 512, options [nop,nop,TS val 3302576859 ecr 3302576859],
length 0
14:18:36.786589 IP your.machine.36086 > yummyrecipesforme.com.http: Flags
[P.], seq 1:74, ack 1, win 512, options [nop,nop,TS val 3302576859 ecr
3302576859], length 73: HTTP: GET / HTTP/1.1
14:18:36.786595 IP yummyrecipesforme.com.http > your.machine.36086: Flags
[.], ack 74, win 512, options [nop,nop,TS val 3302576859 ecr 3302576859],
length 0
...<a lot of traffic on the port 80>...

14:20:32.192571 IP your.machine.52444 > dns.google.domain: 21899+ A?
greatrecipesforme.com. (24)
14:20:32.204388 IP dns.google.domain > your.machine.52444: 21899 1/0/0 A
192.0.2.17 (40)
14:25:29.576493 IP your.machine.56378 > greatrecipesforme.com.http: Flags
[S], seq 1020702883, win 65495, options [mss 65495,sackOK,TS val 3302989649
ecr 0,nop,wscale 7], length 0
14:25:29.576510 IP greatrecipesforme.com.http > your.machine.56378: Flags
[S.], seq 1993648018, ack 1020702884, win 65483, options [mss 65495,sackOK,TS
val 3302989649 ecr 3302989649,nop,wscale 7], length 0
14:25:29.576524 IP your.machine.56378 > greatrecipesforme.com.http: Flags
[.], ack 1, win 512, options [nop,nop,TS val 3302989649 ecr 3302989649],
length 0
14:25:29.576590 IP your.machine.56378 > greatrecipesforme.com.http: Flags
[P.], seq 1:74, ack 1, win 512, options [nop,nop,TS val 3302989649 ecr
3302989649], length 73: HTTP: GET / HTTP/1.1
14:25:29.576597 IP greatrecipesforme.com.http > your.machine.56378: Flags
[.], ack 74, win 512, options [nop,nop,TS val 3302989649 ecr 3302989649],
length 0
...<a lot of traffic on the port 80>...